



Information Security Risk Assessment

FlowWing Solutions

Prepared by: Fardeen Sameer Khan

Project type: Independent GRC Case Study

Status: In Progress

Date: September 2026

Organizational Context:

FlowWing Solutions is a fictional Malaysian business to business SaaS company with approximately 40 employees. The company provides a cloud-based project and workflow management platform for small and medium-sized businesses.

FlowWing hosts its application and customer data on AWS, maintains its source code through GitHub, and uses Google Workspace for email and collaboration. Employees work through a hybrid arrangement, while developers and system administrators can remotely access selected production resources.

The company has implemented basic technical safeguards but has not yet established a formal information-security risk-management process. This assessment therefore identifies several priority risks and recommends suitable treatments aligned with ISO/IEC 27001:2022.

Assessment Objective

The objective of this assessment is to identify, analyze, and prioritize information-security risks affecting FlowWing Solutions and to recommend appropriate risk treatments and security controls. The assessment also demonstrates how selected treatments may align with relevant ISO/IEC 27001:2022 Annex A controls.

Assessment Scope

The assessment covers customer information, employee and administrator accounts, the SaaS application, AWS infrastructure, source-code repositories, company-managed laptops, backups, and remote-working practices.

Detailed penetration testing, physical-office security, privacy-law analysis, supplier auditing, and full ISO/IEC 27001 certification readiness are outside the scope of this exercise.

Risk Assessment Methodology

Each identified risk will be assessed using likelihood and impact scores from 1 to 5. The overall risk score will be calculated as:

Risk Score = Likelihood × Impact

Score	Rating
1–4	Low
5–9	Medium
10–16	High
17–25	Critical

The assessment will distinguish between inherent risk, representing the exposure before additional treatment, and residual risk, representing the expected exposure after the recommended controls are implemented.

Risk Register

ID	Risk	Assets	L	I	Rating	Response	Owner	Residual
R1	Unauthorized production access	AWS; client data	4	5	20 Critical	Mitigate	Eng. Lead	TBD
R2	Loss or corruption of customer data	Customer data; AWS; SaaS app	3	5	15 High	Mitigate	Eng. Lead	TBD

R1 Unauthorized Remote Access to Production Resources

Risk statement Unauthorized access to production resources may occur if developers or system administrators connect remotely using unmanaged devices or insufficiently secured network connections. This could result in customer-data exposure, unauthorized system changes, malware infection, or service disruption.

Inherent risk assessment Likelihood is rated 4 because remote production access is regularly required while device, network, and authentication requirements are not consistently enforced. Impact is rated 5 because successful unauthorized access could expose customer information, enable malicious changes to production systems, and cause severe operational, financial, contractual, and reputational consequences. The resulting inherent risk score is 20, rated Critical.

Recommended treatment

- Permit production access only through an approved secure remote-access method, such as a company VPN or zero-trust access service.
- Allow access only from company-managed laptops with encryption, endpoint protection, and current security updates.
- Require multifactor authentication for all production and privileged accounts.
- Apply least-privilege access and review production access periodically.
- Log and monitor remote administrative access and investigate unusual activity.
- Document these requirements in a formal remote-access policy.

Residual risk To be assessed after the proposed controls are evaluated and an expected post-treatment likelihood and impact are agreed.

R2 Loss or Corruption of Customer Data

Risk statement Customer data may be accidentally deleted, corrupted, or rendered unrecoverable due to human error, faulty application changes, malicious activity, cloud misconfiguration, or inadequate backup and recovery arrangements. This could result in prolonged service disruption, financial loss, contractual or regulatory consequences, and reputational damage.

Inherent risk assessment Likelihood is rated 3 because data loss or corruption is a realistic possibility, but there is no evidence that it occurs frequently or that failure is imminent. Impact is rated 5 because unrecoverable customer data could severely disrupt the SaaS service, harm customers, create significant recovery and legal costs, and threaten the viability of the business. The resulting inherent risk score is 15, rated High.

Recommended treatment

- Create automated, scheduled, and encrypted backups of customer data and critical system configurations.
- Store protected backup copies separately from the primary production environment.
- Restrict permissions to modify or delete backups and enable versioning or deletion protection where appropriate.
- Define backup-retention periods based on operational, contractual, and regulatory needs.
- Monitor backup jobs and alert responsible personnel when a backup fails.
- Perform regular restoration tests in a controlled environment to confirm that backups are complete and usable.
- Maintain a documented disaster-recovery procedure with assigned responsibilities and escalation steps.
- Define recovery point and recovery time objectives for critical services and customer data.

Residual risk To be assessed after backup, restoration, and disaster-recovery controls are implemented and an expected post-treatment likelihood and impact are agreed.